Seguridad en Redes y Análisis Inteligente de Amenazas

Tema 7. Seguridad en redes inalámbricas

Índice

Esquema

Ideas clave

7.1. Introducción y objetivos

7.2. Wired Equivalent Privacy: WEP

7.3. Wifi Protected Access: WPA

7.4. Wifi Protected Access 2: WPA2

7.5. Wifi Protected Access 3: WPA3

7.6. Referencias bibliográficas

A fondo

WLAN Security Enhancements: WPA3, OWE and DPP

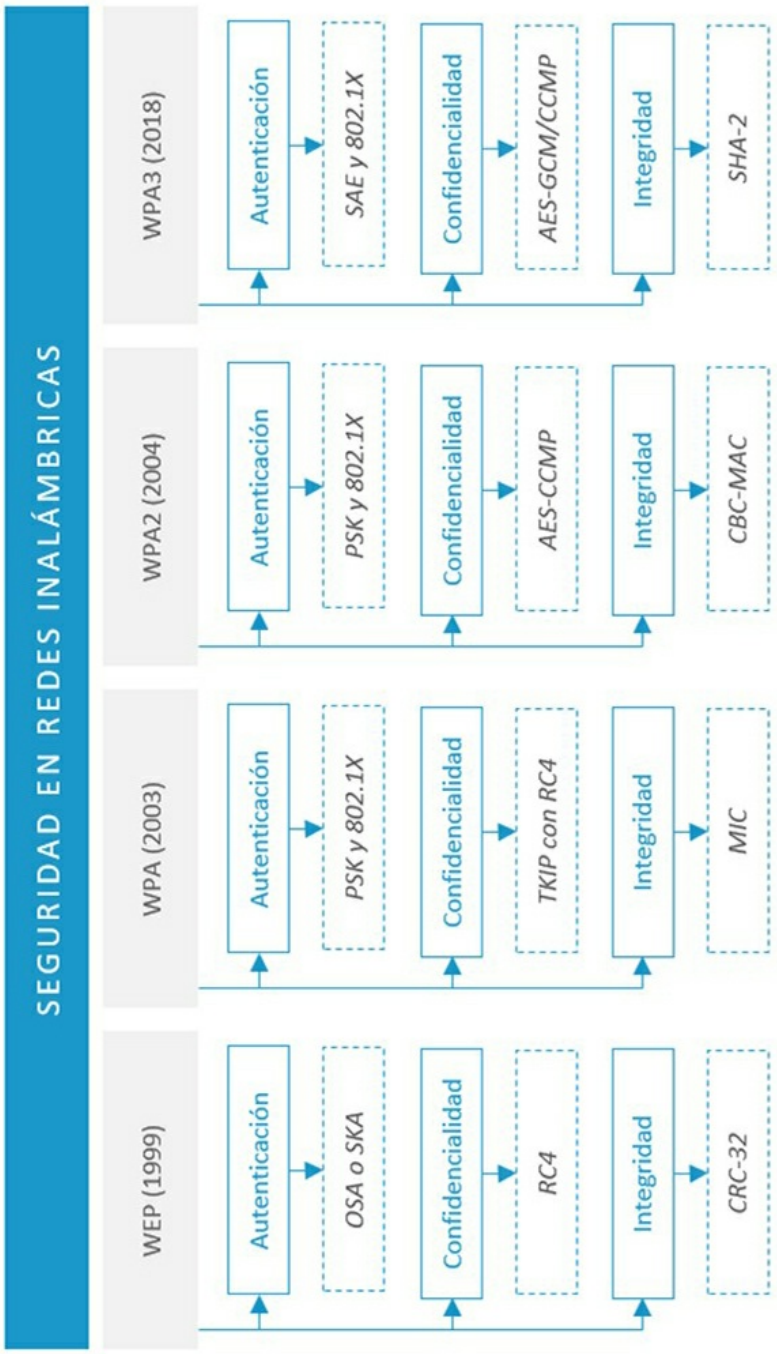
Fragment and Forge: Breaking Wi-Fi Through Frame Aggregation and Fragmentation

Dragonblood: Analysing WPA3's Dragonfly Handshake

Release the Kraken: New KRACKs in the 802.11 Standard

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

7.1. Introducción y objetivos

Las **primeras redes inalámbricas** surgieron como un complemento a las redes de área local cableadas para dotar de mayor movilidad a los usuarios a través de un acceso inalámbrico de corto alcance para dispositivos electrónicos.

A medida que este tipo de redes fueron evolucionando y ganando aceptación, surgió la necesidad de crear una **tecnología inalámbrica** que permitiera asegurar la compatibilidad entre equipos de diversos fabricantes. Con el objetivo de alcanzar esa meta, en 1999 un grupo de empresas se unió para crear la organización Wireless Ethernet Compatibility Alliance (WECA), actualmente conocida como WiFi Alliance.

En abril de 2000, WECA certificó la norma IEEE 802.11b, bajo la marca WiFi; certificando que los equipos que incluyese este **sello WiFi podrían interactuar entre ellos con independencia de su fabricante.**

El estándar utilizado por WiFi, IEEE 802.11, opera en la capa física de la pila TCP/IP y es análogo al protocolo IEEE 802.3 (Ethernet) para redes locales cableadas. Además, se diseñó de manera que se mantuviera una completa compatibilidad con este.

Desde la creación del primer estándar IEEE 802.11, esta familia de estándares ha ido evolucionando y mejorando aspectos como el rango y velocidad de la transferencia de información, la seguridad, etc. a través de la definición de nuevos estándares IEEE 802.11, tales como: IEEE 802.11b, IEEE 802.11g, IEEE 802.11i, IEEE 802.11n, IEEE 802.11ac (WiFi 5), IEEE 802.11ax (WiFi 6), etc.

Este tipo de redes se encuentran disponibles en prácticamente casi todos los ámbitos (universidades, centros de investigación, aeropuertos, cafeterías e incluso hogares) y se utilizan para el intercambio de diversos tipos de información. Este uso cada vez más generalizado y diverso ha motivado la aparición de diversos

© Universidad Internacional de La Rioja (UNIR)

mecanismos de seguridad para evitar accesos no deseados a este tipo de redes y proteger la información que en ellas se encuentra.

Los **objetivos** del tema se resumen a continuación:

- Conocer la evolución de los protocolos de redes inalámbricas más utilizados hasta la fecha.
- Identificar las vulnerabilidades que se han identificado en protocolos previos.
- Estudiar la solución propuesta a las vulnerabilidades anteriores utilizando los nuevos protocolos.
- Ser capaces de escoger los protocolos adecuados para securizar redes inalámbricas en función de las propiedades de estas.

© Universidad Internacional de La Rioja (UNIR)

7.2. Wired Equivalent Privacy: WEP

Wired Equivalent Privacy (WEP) forma parte del estándar IEEE 802.11b y fue creado con la idea de proporcionar una seguridad a las redes inalámbricas comparable a la de una red tradicional cableada.

Autenticación

El principal uso de la autenticación en redes inalámbricas consiste en controlar qué equipos cliente (o estaciones) pueden acceder a la red por medio de un punto de acceso (AP, *access point*). En las redes cableadas, el acceso a estas es más sencillo, ya que basta con conectarnos físicamente.

En una red de área local inalámbrica (WLAN, *Wireless Local Area Network*) primero se ha de tener acceso a la red objetivo. Posteriormente, la estación debe autenticarse para poder conectarse a la red por medio de un punto de acceso.

Para realizar este proceso, los puntos de acceso envían periódicamente difusiones de tramas de gestión (*management frames*), anunciando la existencia de la red. Una estación puede descubrir los *management frames* que se están enviando y así saber qué redes hay disponibles o bien enviar activamente solicitudes de detección (*probe requests*) a todos los canales para ver en qué canales hay un AP emitiendo.

Finalmente, la estación selecciona una red a la que accede para realizar un proceso de autenticación que en el caso de WEP puede ser:

Open System Authentication (OSA)

Cualquier estación puede enviar una solicitud de autenticación con el algoritmo de autenticación a 0 (es decir, OSA) y, si el AP permite este algoritmo de autenticación como válido, permitirá que la estación se una a la red exitosamente.

OSA realmente no otorga un mecanismo de autenticación, de modo que, aunque

© Universidad Internacional de La Rioja (UNIR)

está contemplado en WEP, no resuelve el problema de autenticación que se trata en este punto.

Shared Key Authentication (SKA)

Este método se basa en un sistema de reto respuesta para comprobar que el cliente conoce la clave compartida. De esta forma, solo las estaciones que conozcan la clave compartida tendrán acceso a la red.

Como se muestra en la Figura 1, el cliente solicita autenticarse al AP y este le envía un reto. Este reto se debe cifrar con la clave compartida para demostrar que se conoce y enviarse devuelta al AP. Como resultado, el AP enviará un mensaje indicando si se ha superado o no el reto y, en consecuencia, se dispondrá o no de acceso a la red inalámbrica.

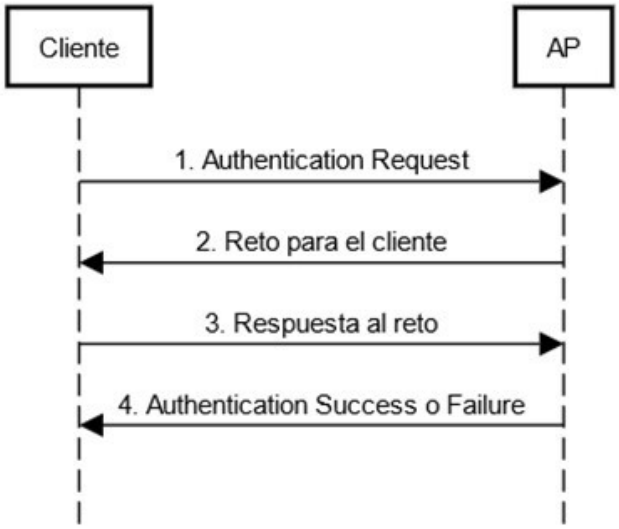


Figura 1. Esquema de autenticación SKA. Elaboración propia.

Problemas en la autenticación

La autenticación que usa SKA **no permite que el AP diferencie a uno clientes de otros,** solo es capaz de saber si el cliente conoce la clave compartida, pero no si es un cliente específico, ya que no hay forma de asociar claves específicas a cada

© Universidad Internacional de La Rioja (UNIR)

cliente.

No es posible que el cliente autentique al punto de acceso y esto implica que es posible realizar un ataque de tipo *rogue* AP y hacerse pasar por él. Ser capaces de ocupar el papel del punto de acceso da un gran poder a los atacantes, ya que toda la información pasa por ellos.

Confidencialidad

WEP utiliza una clave precompartida en su proceso de cifrado, siguiendo los pasos que se muestran a continuación (ver Figura 2):

- Añade una comprobación de identidad al mensaje (ICV es un sinónimo de un MIC, *Message Integrity Check*).
- Selecciona un vector de inicialización (IV) que concadena con la clave compartida y utiliza como clave del cifrador de flujo RC4 para generar una secuencia cifrante.
- El mensaje a cifrar (*MAC Protocol Data Unit*, MPDU) más el MIC (o ICV) se suman XOR con la secuencia cifrante y al criptograma resultado se le añade una cabecera de 4 bytes incluyendo los 3 bytes del IV y un byte para una posible elección de clave precompartida que en la práctica no se utiliza.

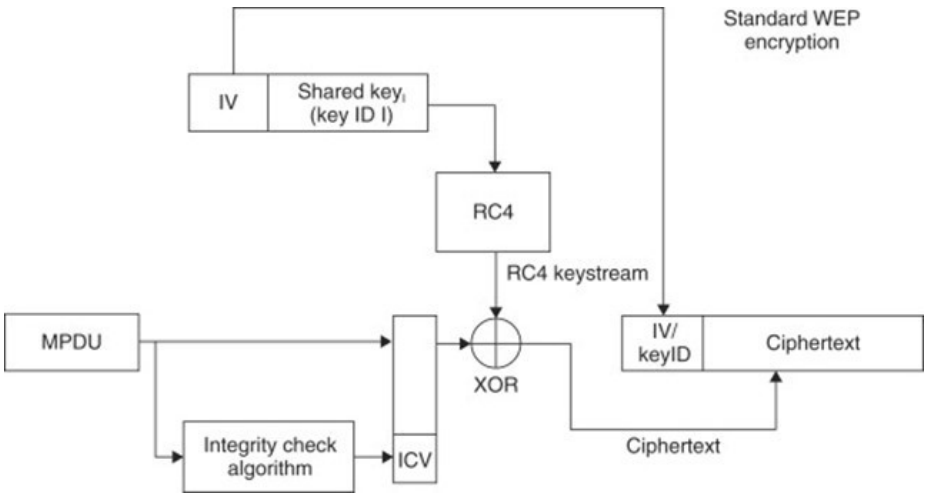


Figura 2. Esquema de cifrado usando WEP. Fuente: (Chandra, 2011).

© Universidad Internacional de La Rioja (UNIR)

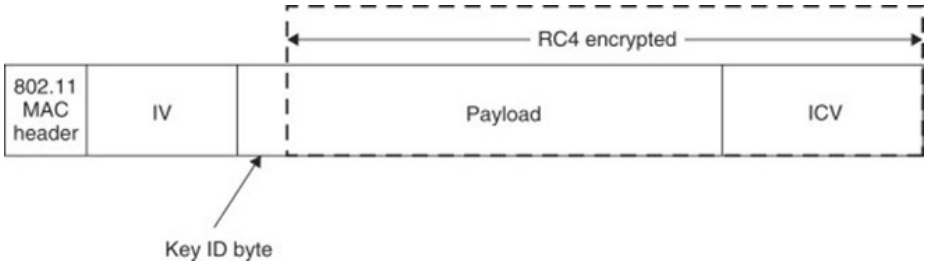


Figura 3. Esquema de un paquete WEP. Fuente: (Chandra, 2011).

Problemas en la confidencialidad

RC4 es un algoritmo de cifrado en flujo, lo que implica que tanto el emisor del mensaje como el receptor han de estar en fase (sincronizados). Un escenario inalámbrico no es ideal para este tipo de sincronización debido a su alta tasa de errores en la comunicación. Este fue un problema de diseño de WEP que derivó en soluciones *ad hoc* que hicieron este protocolo inseguro.

Integridad

Para garantizar que los paquetes llegan a su destino tal y como fueron emitidos, 802.11 utiliza un campo de integridad (ICV o MIC). Gracias al uso de este campo, el destino es capaz de regenerar el MIC con el paquete recibido y comparar con el MIC original para determinar si el paquete ha sido modificado en tránsito o no (preservando así su integridad). En la Figura 3 se puede ver el uso de WEP junto a CRC-32 (función de redundancia cíclica) para crear una trama de transmisión completa (MPDU).

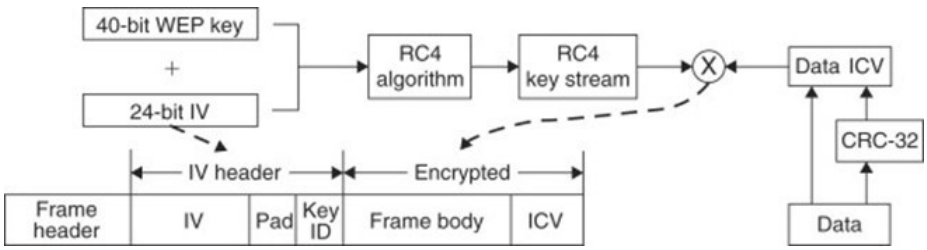


Figura 4. Esquema del uso del CRC32 junto a WEP. Fuente: (Chandra, 2011).

© Universidad Internacional de La Rioja (UNIR)

Resumiendo WEP

- Proporciona un mecanismo de **autenticación** que comprueba la **posesión de la misma clave compartida** utilizada para el cifrado (SKA).
- Utiliza el algoritmo de cifrado Rivest Cipher 4 (RC4) con **clave estática compartida por todos los usuarios de la red** de 64 y 128 bits, incluyendo un vector de inicialización (IV) de 24 bits, para dotar de **confidencialidad** a las comunicaciones.
- Hace uso de un código de redundancia cíclica CRC-32 **para lograr la integridad** de las comunicaciones.

A partir de 2001, se empezaron a detectar múltiples vulnerabilidades en WEP debido principalmente a ciertos errores en su diseño:

- Uso de una única clave estática compartida por todos los usuarios.
- Vector de inicialización de 24 bits, lo que provoca colisiones en puntos de acceso muy concurridos.
- Uso de un control de integridad lineal como es CRC-32.
- Uso del algoritmo de cifrado RC4 pensado para comunicaciones síncronas y no para comunicaciones con una tasa de error considerable.
- El ICV (o MIC) utilizado no protege la integridad de la cabecera, lo que permite los ataques de redirección.
- Autenticación de una dirección: el cliente no puede autenticar al punto de acceso.

A través del análisis de las debilidades del protocolo WEP, surgieron numerosos ataques que terminaron en el desarrollo de varias herramientas de dominio público, como *Airsnort*, *WEPCrack* o *Aircrack*, que permiten la obtención de la clave compartida utilizada en este tipo de redes.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

WEP hoy en día es considerado **inseguro.** Su uso no está recomendado, salvo en casos donde sea la única opción disponible, y **debe substituirse por WPA3** (o WPA2, si WPA3 no está disponible).

© Universidad Internacional de La Rioja (UNIR)

7.3. Wifi Protected Access: WPA

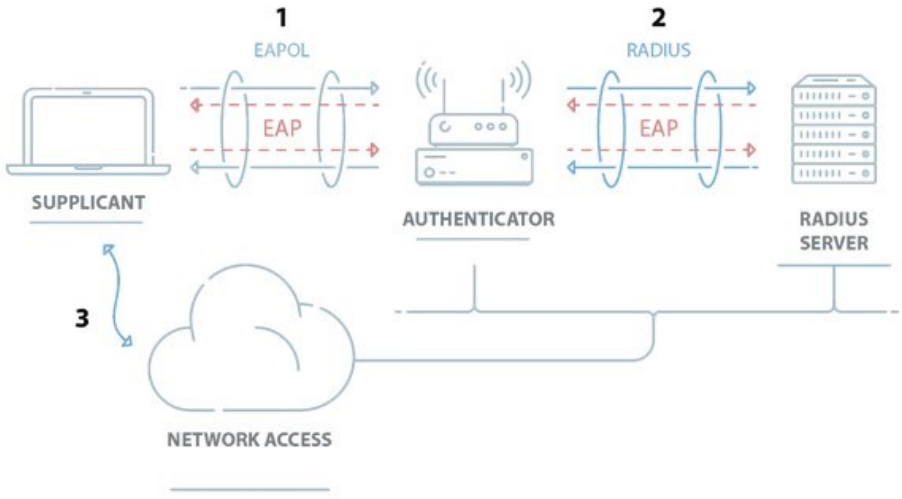
Teniendo en cuenta la inseguridad de WEP, el IEEE comenzó a trabajar en un nuevo estándar, IEEE 802.11i, publicado en 2004, que permitiese mejorar la seguridad de las comunicaciones inalámbricas. IEEE 802.11i define dos modos de seguridad diferenciados: WPA y WPA2.

WPA está pensado para ser **compatible con el *hardware* existente** y para permitir a redes ya desplegadas poder migrar de WEP a un estándar más seguro. Aparecía WPA, por tanto, como una solución transitoria hasta que se pudiera dar el salto a WPA2.

Autenticación

Para las redes domésticas el estándar 802.11i en **WPA-Personal** permite el uso de claves precompartidas (*Pre-Shared Key*, PSK), de forma similar a lo que sucedía con WEP.

En redes empresariales (o en redes domésticas en las que sea posible esta implementación) el estándar 802.11i en **WPA-Enterprise** especifica el uso de IEEE 802.1X para el establecimiento de claves y la autenticación.



© Universidad Internacional de La Rioja (UNIR)

Figura 5. Esquema de autenticación utilizando 802.1X. Fuente: https://www.securew2.com/solutions/802-1x.

La identidad del usuario se determina con base en sus credenciales (o a su certificado digital), las cuales se confirman por medio de un servidor *Remote Authentication Dial In User Service* (RADIUS). El servidor RADIUS realiza esta operación comunicándose internamente con el directorio activo de la organización, típicamente por medio de los protocolos LDAP o SAML.

El protocolo de autenticación usado es *Extensible Authentication Protocol* (EAP), el cual facilita un método seguro por el que enviar la información de autenticación por un canal inalámbrico. Se utilizará un túnel EAP que evitará que los terceros que intercepten la comunicación puedan acceder a la información sensible.

Se puede configurar EAP para utilizar credenciales (EAP-TTLS/PAP y PEAP-MSCHAPv2) y certificados digitales (EAP-TLS), y es un método altamente recomendable en el proceso de autenticación.

Confidencialidad

Uno de los problemas que aparecían en WEP consiste en el uso de la misma clave para todos los clientes y todos los paquetes tanto para la autenticación como para el cifrado. En el caso de WPA, se utiliza el protocolo TKIP (*Temporal Key Integrity Protocol*), con el objetivo de utilizar claves de cifrado diferentes para cada sesión de usuario, exponiendo así en menor medida la clave precompartida (utilizada en autenticación).

Inicialmente, TKIP utiliza la clave maestra de la red PMK (*Pair-wise Master Key*) para generar un conjunto de PTK (*Pair-wise Transient Key*), que son claves de sesión temporales de 128 bits. Por último, cada paquete se cifrará con una clave diferente (usando RC4 por compatibilidad *hardware*) que resulta de aplicar una PTK a una función de mezcla de clave (ver Figura 6). En cada nueva asociación de una estación

© Universidad Internacional de La Rioja (UNIR)

con un AP se genera un nuevo conjunto de PTK derivadas de la PMK.

Para hacer que las claves de sesión sean diferentes, se utilizan nonce (*number used once*). Estos serán números aleatorios utilizados una única vez y generados uno por la estación (Snonce) y otro por el AP (Anonce), que se combinarán con la PMK para generar el conjunto de PTK de la sesión.

La construcción del conjunto de PTK, se realiza en el 4-*way handshake* (ver Figura 6), en el que el AP adicionalmente a lo comentado antes utiliza una GTK (clave de grupo temporal). El cálculo de PTK queda como sigue:

PTK = PMK + ANONCE + SNONCE + MAC(AP) + MAC(Estación)

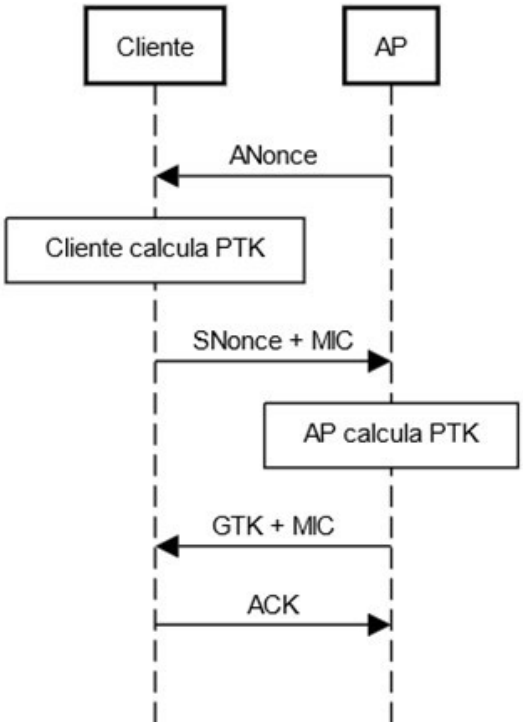


Figura 6. 4-*way handshake* de WPA/WPA2. Elaboración propia.

Adicionalmente, TKIP duplica el tamaño de IV pasando de 24 bits a 48 bits, haciendo así que el tiempo de colisión de IVs en una red de carga media pase de unas pocas

© Universidad Internacional de La Rioja (UNIR)

horas a unos pocos años.

Recordemos que WPA es un protocolo transitorio cuyo uso debía restringirse hasta poder actualizar el *hardware* implicado en nuestras redes inalámbricas y así utilizar WPA2. Por tanto, incrementar simplemente el tamaño del IV y concatenarlo con la clave no era una opción, ya que esto implicaría un cambio al *hardware* usado en WEP. Es por este motivo por el que se utiliza una función de mezcla de clave que permite el uso de IVs de 48 bits manteniendo la retrocompatibilidad.

Integridad

WEP utiliza una comprobación de integridad lineal con un código de redundancia cíclico (CRC-32). Es computacionalmente ligero, pero no genera una integridad criptográficamente segura (se pueden modificar los paquetes consiguiendo que este campo no se vea modificado).

El reto de WPA era conseguir un algoritmo criptográficamente seguro, pero cuya complejidad computacional fuera reducida para que pudiera correr en los dispositivos WEP que poseían una capacidad reducida. Por este motivo, TKIP utiliza MICHAEL un protocolo ligero nuevo para calcular su MIC, solo utiliza operaciones de desplazamiento y de adición.

Como puede verse en la Figura 6, el valor del MIC de MICHAEL se añade a la MPDU al campo ICV y se sigue utilizando el CRC-32 (recordemos que se siguen utilizando los dispositivos de WEP). Es importante indicar aquí que MICHAEL mejora CRC-32, pero no llega a los niveles de seguridad que aportaría en su entonces SHA-1. Sabiendo esta situación, los creadores de TKIP implementaron una funcionalidad para evitar que los atacantes pudieran aprovechar esa posible debilidad en MICHAEL. Para esto, si se detectan dos paquetes con MIC erróneos en un segundo, la estación asume que está sufriendo un ataque y como contramedida se desasocia del AP un minuto y se reasocia de nuevo regenerando todas las claves. Como consecuencia inesperada, este mecanismo facilita ataques de DoS en este tipo de

© Universidad Internacional de La Rioja (UNIR)

redes.

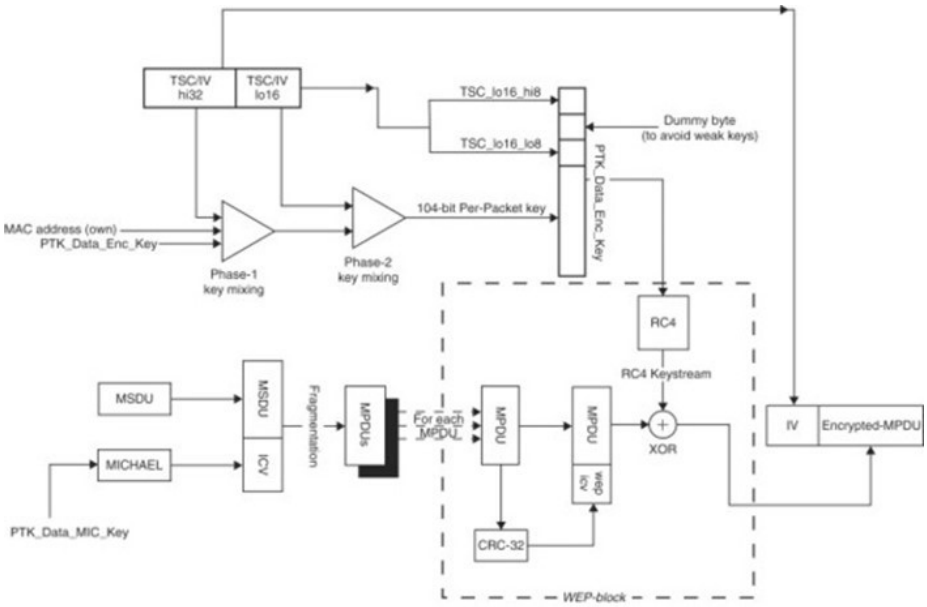


Figura 7. Esquema de confidencialidad e integridad en WPA. Fuente: (Chandra, 2011).

Resumiendo WPA

- Incorpora un mecanismo de gestión de claves dinámicas ***Temporal Key Integrity Protocol*** **(TKIP) al cifrado RC4.**
- Usa **claves dinámicas** (cambian más o menos cada 10 000 paquetes enviados) y que varían para cada usuario (se combina con la dirección MAC del dispositivo del usuario); lo que conlleva una mejora significativa de la seguridad de la red.
- Incorpora un nuevo algoritmo de control de **integridad** conocido como **Michael** para generar un *Message Integrity Check* (MIC).
- Soporta tanto **autenticación basada en clave compartida (WPA-Personal)** como con **claves diferentes para cada usuario (WPA-Enterprise)** basado en el estándar 802.1X que utiliza un servidor *Remote Authentication Dial In User Service* (RADIUS) de autenticación.

© Universidad Internacional de La Rioja (UNIR)

7.4. Wifi Protected Access 2: WPA2

WPA2, por su parte, suponía una ruptura con el *hardware* existente, así pues, era posible utilizar un algoritmo de cifrado simétrico diferente. Se propone el uso de ***Advanced Encryption Standard* (AES),** que es con una diferencia notable el algoritmo de cifrado simétrico más utilizado en la actualidad.

Autenticación

WPA2 comparte con WPA la gestión de claves y la arquitectura de autenticación (permitiendo tanto los modos *Personal* como *Enterprise*). En cuestiones de confidencialidad e integridad, WPA2 utiliza AES-CCMP en lugar de los utilizados por WPA: TKIP y MICHAEL.

Confidencialidad e integridad

Es en el apartado de confidencialidad, teniendo en cuenta que WPA2 no necesita ser retrocompatible con los dispositivos utilizados en WEP, donde tiene lugar uno de los grandes cambios que introduce WPA2. Como algoritmo de cifra simétrica se escoge **el algoritmo de cifra en bloque AES,** que es el algoritmo de cifra simétrica que sigue siendo más utilizado hoy en día, no solo en redes inalámbricas sino en cualquier comunicación que use cifrado simétrico.

AES es un algoritmo de cifrado que resuelve la propiedad de confidencialidad, pero escogiendo un modo de cifra específico, en concreto el modo de cifra **CCMP** (*Counter Mode Cipher Block Chaining Message Authentication Code Protocol*), será capaz de ofrecer confidencialidad e integridad. Por esto, al protocolo de cifra se le llama AES-CCMP.

© Universidad Internacional de La Rioja (UNIR)

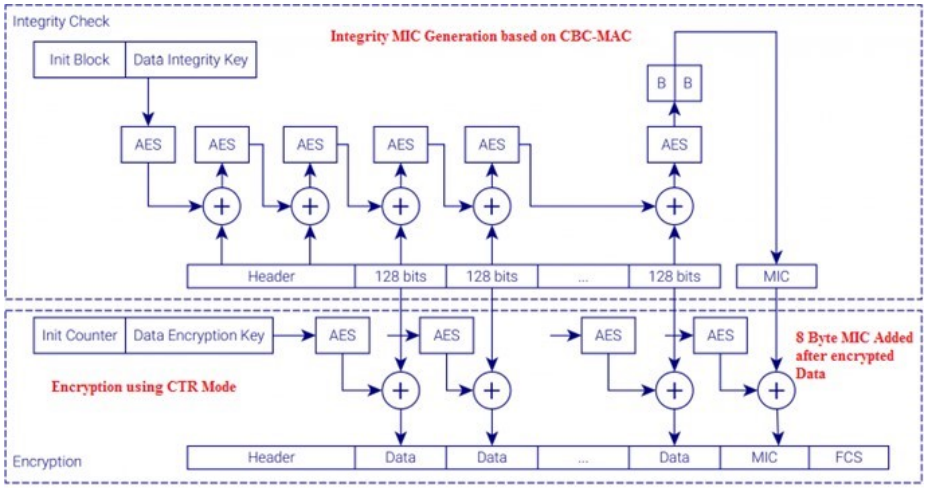


Figura 8. Esquema general de uso de WPA2. Fuente: https://praneethwifi.in/2020/05/02/ctr-with-cbc-mac-protocol-ccmp-aes-ccmp/

Este modo de cifra combina:

- Modo CTR (*Counter Mode*) para obtener la confidencialidad de los bloques de datos cifrados.
- Modo CBC-MAC para garantizar además la integridad y autenticación que resulta en el MIC de bytes que se añade tras los datos cifrados.

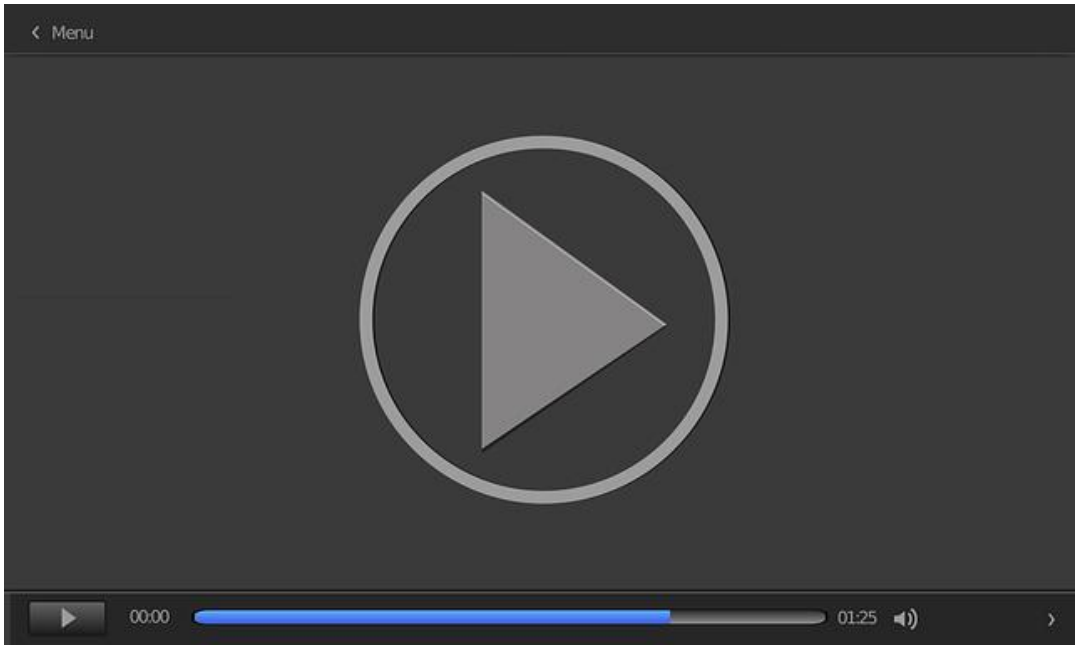
Resumiendo WPA2

- Usa el modo Coun*ter Cipher Mode with Block Chaining Message Authentication Code Protocol* (CCMP) de AES **(AES-CCMP)** que provee tanto de confidencialidad como de integridad y autenticación a los paquetes.
- Usa **claves dinámicas** (cambian más o menos cada 10 000 paquetes enviados) y que **varían para cada usuario** (se combina con la dirección MAC del dispositivo del usuario); lo que conlleva una mejora significativa de la seguridad de la red.
- Al igual que WPA soporta tanto **autenticación basada en clave compartida (WPA2-*Personal*)** como con **claves diferentes para cada usuario (WPA2-*Enterprise*)** basado en el estándar 802.1X que utiliza un servidor *Remote*

© Universidad Internacional de La Rioja (UNIR)

Authentication Dial In User Service (RADIUS) de autenticación.

En el vídeo, *Diferencias entre WPA y WPA2: un vistazo a las capturas de red*, se revisan dos trazas de tráfico de WPA y WPA2 para enfatizar las diferencias entre estos protocolos.



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=9d454cd5-3a20-4074-bee3-af63012d6385

© Universidad Internacional de La Rioja (UNIR)

7.5. Wifi Protected Access 3: WPA3

En el año 2017, aparece el ataque *Key Reinstallation Attack*, KRACK (Vanhoef & Piessens, 2017) que supone una vulnerabilidad crítica en el 4-*way handshake* utilizado en las redes WPA/WPA2. Esto forzó a la Wi-Fi alliance a buscar urgentemente una solución resultando en la aparición de WPA3 en 2018 (la versión 3 de este estándar se publicó el 14 de diciembre de 2020).

Autenticación

Al igual que WPA2, WPA3 permite dos modos de funcionamiento: *Personal* y *Enterprise*. En el modo *Personal* se usa una clave de red precompartida y en modo *Enterprise* se utiliza un servidor RADIUS con el protocolo 802.1x para realizar la autenticación.

SAE (*Simultaneous Authentication of Equals*)

En cuestiones de autenticación, WPA3 reemplaza la generación de PSK de TKIP con el protocolo SAE (*Simultaneous Authentication of Equals*), que es una modificación del ya conocido protocolo *dragonfly* (RFC 7664) y consiste en una ZKP (*Zero Knowledge Proof*). Tras la obtención de la PMK usando SAE se utilizará también el 4-*way handshake* (ver Figura 6) con el que se derivarán las claves temporales. Este 4-*way handshake* no es susceptible de ataques gracias al diseño de SAE capaz de generar una PMK siendo robusto a ataques *offline* de diccionario.

En SAE se utiliza el intercambio de clave de Diffie-Hellman, añadiendo a esto un elemento de autenticación. Se crea una clave compartida con métodos de curva elíptica y añadiendo una clave precompartida y las direcciones MAC. En la conexión del cliente con el AP se realiza un intercambio SAE. Si este intercambio se lleva a cabo de forma exitosa, ambos extremos compartirán una clave de la que se derivará la clave de sesión. Si un atacante es capaz de descubrir una clave de sesión, solo

© Universidad Internacional de La Rioja (UNIR)

afectará a esta clave y no al resto de claves utilizadas previa o posteriormente (como sí sucedía en WPA2).

SAE se divide en fases de compromiso (*commit*) y confirmación (*confirm*). Una vez se acuerda un compromiso, tanto cliente como AP pasan a la fase de confirmación, esto se realiza por cada clave de sesión que se va a generar. Este método presenta la propiedad de secreto hacia adelante (*forward secrecy*), de modo que, cuando un atacante consigue una contraseña de sesión, esto no le dará información de las claves de sesión siguientes o previas.

En la *fase commit* (ver la Figura 9) el cliente genera dos números aleatorios (a y A) y calcula su suma (sA) en el módulo *q* escogido que es público y un número primo de una gran dimensión. El cliente envía PE el valor equivalente de la clave maestra (un *hash* de esta y las MAC asociadas) elevado a -A. El AP hace lo mismo escogiendo dos números aleatorios (b y B), calculando su suma sB y enviando PE^{-B}.

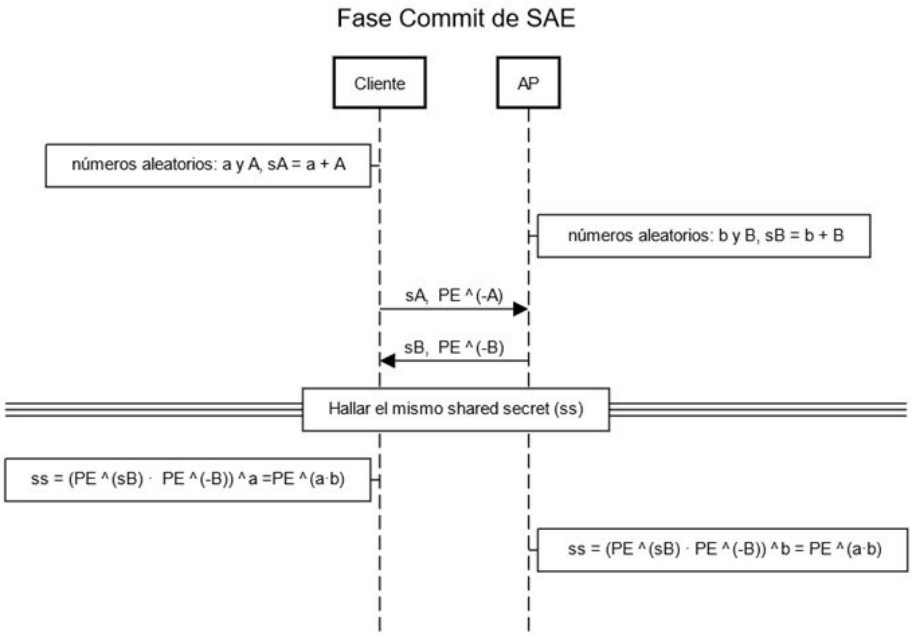


Figura 9. Fase *commit* de SAE. Elaboración propia.

Tras este intercambio, ambos extremos multiplican el valor recibido por PE elevado a

© Universidad Internacional de La Rioja (UNIR)

la suma de números aleatorios secretos recibida y el resultado lo elevan a su número secreto, alcanzando el mismo secreto compartido (ss):

$$(\text{cliente}) \rightarrow \text{ss} = \left(PE^{\text{sB}} \cdot PE^{-B}\right)^{a} = \left(PE^{b+B-B}\right)^{a} = PE^{\text{a}\cdot\text{b}}$$

$$(\text{AP}) \rightarrow \text{ss} = \left(PE^{\text{sA}} \cdot PE^{-A}\right)^{b} = \left(PE^{a+A-A}\right)^{b} = PE^{\text{a}\cdot\text{b}}$$

Este mismo procedimiento se puede realizar utilizando curvas elípticas en lugar de la exponenciación que utiliza Diffie-Hellman tradicional, el concepto sería el mismo, aunque el uso se base en curvas elípticas.

En la fase *confirm* se obtiene la clave PMK que se usará para generar la clave de sesión con la que cifrar. Así, si un atacante descubre la clave de sesión no podrá recuperar la clave maestra PMK. Para obtener la PMK, se utilizará una función *hash*, el secreto compartido de la fase anterior y algunos de los valores utilizados para calcular el secreto compartido.

No es computacionalmente tratable realizar ataques de diccionario *offline,* ya que la comprobación de si la PMK es la correcta o no queda protegida por el problema del logaritmo discreto (con Diffie-Hellman tradicional) o por la criptografía de curva elíptica (con ECDH).

Wi-Fi Easy Connect

Existían numerosas vulnerabilidades asociadas a WPS, pero es cierto que es necesario disponer de un mecanismo similar especialmente para dispositivos que no posean un método de entrada para introducir la contraseña maestra de la red (dispositivos IoT).

WPA3 propone *Wi-Fi Easy Connect*, que se basa en el protocolo DPP (*device provisioning protocol*) que permite que el cliente se asocie a una red mediante un código, una contraseña y también a través de canales como NFC o Bluetooth.

Confidencialidad e integridad

© Universidad Internacional de La Rioja (UNIR)

AES-GCM (Galois/Counter Mode)

Como algoritmo de cifra simétrica se escoge el **algoritmo de cifra en bloque AES,** rey del cifrado simétrico en la actualidad. En cuanto al modo de cifra, a diferencia de lo que se proponía en WPA2, se propone GCM (Galois/Counter Mode) que otorga **confidencialidad e integridad.**

En el caso del modo personal, se utiliza AES-GCM de 128 bits y en el modo Enterprise AES-GCM con 192 bits de clave. Este modo de cifrado sigue siendo compatible con los dispositivos WPA2, lo que hace que la actualización a WPA3 sea más sencilla.

PMF (*Proteted Management Frames*)

PMF añade protección a las tramas de gestión (*management frames*) tanto *unicast* como *multicast*. En el caso de *multicast,* el uso de PMF aporta integridad a las tramas de gestión; mientras que en el caso de *unicast,* aporta integridad y confidencialidad al cifrar estas tramas de igual forma que las tramas de datos.

PMF fue ideado para evitar ataques como desconexión, *honeypot* y *evil twin attacks*. En este tipo de ataques, el atacante se hace pasar por el AP forzando al cliente a desasociarse de la red o conectarse a un AP falso que el atacante previamente ha preparado para ello.

La implementación de PMF es obligatoria para todos los dispositivos que implementen WPA3.

OWE (*Oportunistic Wireless Encryption*)

Opportunistic Wireless Encryption (OWE) es una nueva característica de WPA3 que reemplaza la autenticación «abierta», utilizada en *hotspot* y redes públicas. La idea básica tras OWE es que, aunque no se necesite conocer la contraseña para asociarse a una red pública, es importante que las comunicaciones viajen cifradas

© Universidad Internacional de La Rioja (UNIR)

para preservar la confidencialidad entre cliente y AP. Gracias a OWE, cada cliente posee una clave de sesión única que comparte con el AP, lo que protege a los clientes de que otros participantes de la red puedan consultar las comunicaciones que están llevando a cabo.

Para conseguir estas claves de sesión el cliente, realiza un intercambio de clave de Diffie-Hellman en los mensajes de solicitud de asociación y de respuesta de asociación, llegando a una PMK compartida. Esta PMK será utilizada en el posterior 4-*way handshake* para derivar las claves de sesión que se utilizarán en esta comunicación.

Aunque OWE mejora frente a las redes abiertas tradicionales de WPA2, sigue siendo vulnerable frente a ataques de MITM (*rogue* AP), ya que no autentica de ninguna manera al AP.

Evolución de la seguridad en Wi-Fi

En la Figura 8 se presenta una comparativa resumen de los distintos protocolos de seguridad Wi-Fi respecto a sus características más representativas.

	WEP	WPA	WPA2	WPA3
Año	1999	2003	2004	2018
Cifrado	RC4	TKIP con RC4	AES-CCMP	AES-GCM (o CCMP)
Tamaño clave	40 bits + IV 104 bits + IV	128 bits	128 bits	128 bits (Personal) 192 bits (Enterprise)
Integridad	CRC-32	MIC	CBC-MAC (en CCMP)	Hash (SHA-2)
Gestión de clave	---	4-way handshake	4-way handshake	SAE
Autenticación	OSA o SKA	PSK y 802.1X	PSK y 802.1X	SAE y 802.1X

Figura 11. Comparación de los distintos protocolos de seguridad Wi-Fi. Elaboración propia.

Se **recomienda el uso de WPA3, preferentemente** en su versión **Enterprise** para el despliegue de una red inalámbrica siempre que sea posible. Para entornos donde el establecimiento de la arquitectura necesaria para 802.1X no sea posible se

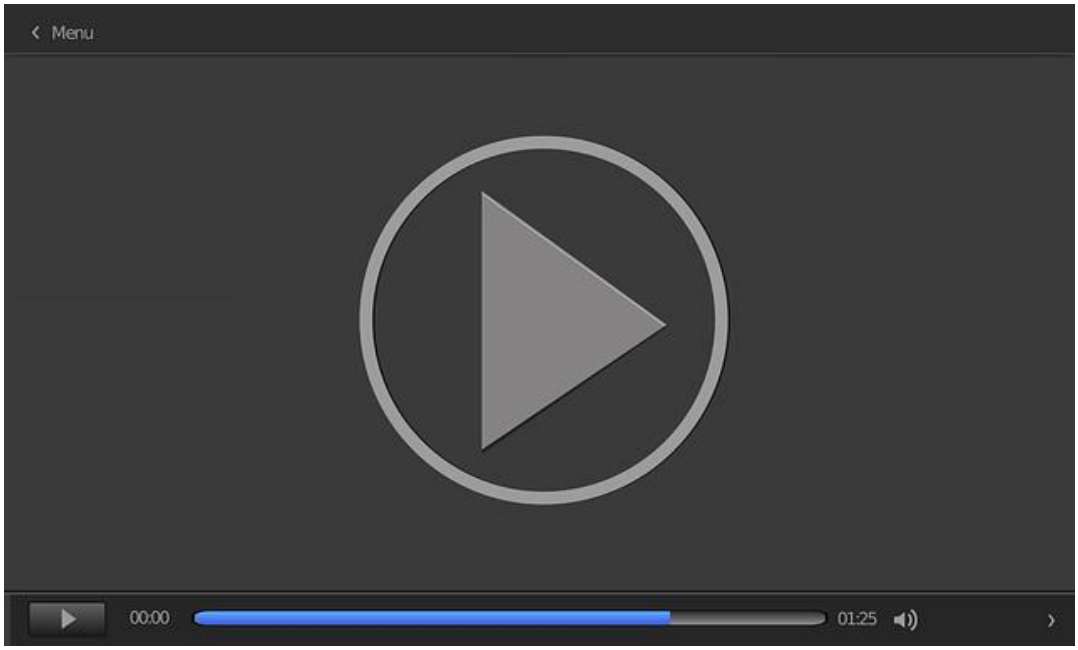
© Universidad Internacional de La Rioja (UNIR)

recomienda el uso de WPA3-Personal con una clave compartida segura.

En caso de no poder utilizar WPA3, **se desaconseja el uso** de cualquiera de las variantes de WPA a no ser que los dispositivos utilizados no sean compatibles con WPA2 y se ha de evitar el uso, siempre que sea posible, de WEP.

Aun así, en estos últimos años siguen apareciendo vulnerabilidades importantes incluso en el protocolo más actual WPA3. Algunos ejemplos de estos ataques son: Dragonblood (Vanhoef & Ronen, 2020) y FragAttacks (Vanhoef, 2021) que han sido descubiertos por el mismo investigador que el famoso KRACK que derribó WPA2.

En el vídeo, *Análisis de SAE en una traza de WPA3*, se realiza un análisis con Wireshark de una traza de tráfico de WPA3 utilizan SAE.



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=eec6cde0-b08d-4147-abda-af63012d9093

© Universidad Internacional de La Rioja (UNIR)

7.6. Referencias bibliográficas

Chandra, P. (2011). *Wireless Security: Know It All*. Newnes. https://learning.oreilly.com/library/view/wireless-security-know/9781856175296/

Ramachandran, Vivek. B. y Cameron. (2018). *Kali linux wireless penetration testing beginner's guide—Third edition*. PACKT Publishing Limited.

Vanhoef, M. (2021). *Fragment and Forge: Breaking {Wi-Fi} Through Frame Aggregation and Fragmentation.* 161-178. https://www.usenix.org/conference/usenixsecurity21/presentation/vanhoef

Vanhoef, M., y Ronen, E. (2020). Dragonblood: Analyzing the Dragonfly Handshake of WPA3 and EAP-pwd. *2020 IEEE Symposium on Security and Privacy* (SP), 517-533. https://doi.org/10.1109/SP40000.2020.00031

Vanhoef, M., y Piessens, F. (2017). Key Reinstallation Attacks: Forcing Nonce Reuse in WPA2. *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security*, 1313-1328. https://doi.org/10.1145/3133956.3134027

© Universidad Internacional de La Rioja (UNIR)

WLAN Security Enhancements: WPA3, OWE and DPP

Hemant Chaskar (2019). WLAN Security Enhancements: WPA3, OWE and DPP. WLPC Phoenix 2019. [Vídeo]. YouTube. https://www.youtube.com/watch?v=fCsR8aK4mqE

Sesión de cerca de una hora en la que se repasan en bastante detalle las mejoras que ofrece WPA3 en el mundo de las redes LAN inalámbricas. De especial interés la parte en la que explica SAE con ejemplos de criptografía de curva elíptica.

© Universidad Internacional de La Rioja (UNIR)

Fragment and Forge: Breaking Wi-Fi Through Frame Aggregation and Fragmentation

Mathy Vanhoef. Fragment and Forge: Breaking Wi-Fi Through Frame Aggregation and Fragmentation. *USENIX' Security 21*. [Vídeo]. YouTube. https://www.youtube.com/watch?v=OJ9nFeuitIU

Charla de la prestigiosa conferencia internacional de ciberseguridad Usenix Security' 21. En esta charla, de nuevo Mathy Vanhoef presenta unas vulnerabilidades relacionadas con todos los protocolos de seguridad Wi-Fi desde WEP hasta WPA3 que pueden ser explotadas utilizando su FragAttack.

© Universidad Internacional de La Rioja (UNIR)

Dragonblood: Analysing WPA3's Dragonfly Handshake

Mathy Vanhoef. Dragonblood: Analysing WPA3's Dragonfly Handshake. IEEE Symposium on Security and Privacy 2020. [Vídeo]. YouTube. https://www.youtube.com/watch?v=WZyK_v6xa9o

Charla de Mathy Vanhoef impartida en la conferencia IEEE Symposium on Security and Privacy de 2020 en la que presenta vulnerabilidades relacionadas con el protocolo Dragonfly en el que se basa SAE de WPA3.

© Universidad Internacional de La Rioja (UNIR)

Release the Kraken: New KRACKs in the 802.11 Standard

Mathy Vanhoef. *Release the Kraken: New KRACKs in the 802.11. CCS' 18*. [Vídeo]. YouTube. https://www.youtube.com/watch?v=zig05jJcyJ4

Charla de la prestigiosa conferencia internacional de ciberseguridad CCS' 18. En esta charla se describe una ampliación del trabajo realizado por Mathy Vanhoef con KRACK, ataque asociado a la primera vulnerabilidad crítica descubierta para el protocolo WPA2.

© Universidad Internacional de La Rioja (UNIR)

1. WEP:

   A. No utiliza *management frames*.

   B. Utiliza *management frames* y viajan cifrados.

   C. Utiliza *management frames* y sin cifrar.

   D. Ninguna es correcta.

2. En WEP:

   A. El cliente se autentica usando SKA y enviando al AP la clave compartida para demostrar que la conoce.

   B. La integridad se consigue utilizando un *hash* del mensaje.

   C. El cifrado se realiza mediante un cifrado simétrico en bloque.

   D. Ninguna de las anteriores es correcta.

3. El protocolo WPA:

   A. Utiliza el algoritmo de cifrado RC4 para proteger la confidencialidad de las comunicaciones.

   B. Utiliza el algoritmo de cifrado AES para proteger la confidencialidad de las comunicaciones.

   C. Utiliza el algoritmo de cifrado Michael para proteger la confidencialidad de las comunicaciones.

   D. Ninguna de las anteriores.

4. WPA Enterprise:

   A. Utiliza 802.1x para llevar a cabo la autenticación.

   B. WPA no tiene modo *Enterprise* ni *Personal*, esto se añade a partir de WPA2.

   C. Es resistente al ataque KRACK.

   D. Ofrece la misma seguridad que WPA *Personal*.

© Universidad Internacional de La Rioja (UNIR)

5. WPA2:

A. Utiliza el algoritmo de cifrado RC4 para proteger la confidencialidad de las comunicaciones.

B. Utiliza el algoritmo de cifrado AES para proteger la confidencialidad de las comunicaciones.

C. Utiliza el algoritmo de cifrado Michael para proteger la confidencialidad de las comunicaciones.

D. Ninguna de las anteriores.

6. La integridad en WPA2:

A. Se consigue gracias al uso de AES-CCMP.

B. Se consigue utilizando TKIP y MICHAEL.

C. No es una prioridad, ya que debe ser compatible con los dispositivos WEP.

D. Igual que en WEP utilizando un CRC-32.

7. WPA3:

A. No realiza ningún cambio en relación con el algoritmo de cifrado.

B. Dificulta ataques de desautorización gracias a los PMF.

C. El uso de PMF permite la autenticación entre iguales al conocer la clave compartida.

D. Cifra siempre todas las tramas que envía.

8. WPA3 *enterprise* y *personal*:

A. Se diferencian en las mismas características que en WPA2 *Enterprise* y *Personal*. El uso de clave precompartida o de un servidor RADIUS.

B. Usan diferente tamaño de clave de cifrado.

C. Usan mecanismos de integridad diferentes.

D. Ninguna de las anteriores es correcta.

© Universidad Internacional de La Rioja (UNIR)

9. WPA3 SAE:

A. Sustituye el 4-*way handshake* que se usaba en WPA y WPA2.

B. Se basa en el intercambio de Diffie-Hellman, añadiendo autenticación al proceso.

C. No puede utilizar criptografía de curva elíptica.

D. Protege frente a ataques de diccionario *online*.

10. WPA3:

A. Facilita la conexión de dispositivos de IoT gracias Wi-Fi *Easy Connnect*.

B. Sigue utilizando WPS para facilitar la conexión a la red.

C. Elimina la posibilidad de conectarse a la red de forma simplificada (similar a WPS) por sus implicaciones en cuestiones de seguridad.

D. Utiliza PMF para facilitar la conexión de dispositivos con tecnología NFC.

© Universidad Internacional de La Rioja (UNIR)